

Technische Hochschule Deggendorf

Fakultät Angewandte Informatik

Studiengang Bachelor Cyber-Security

Kurs: Security Engineering – SS 2026

Themenanmeldung

Secure DevOps (DevSecOps) – Sicherheitstechnische Betrachtung automatisierter CI/CD-Pipelines

Vorgelegt von:

Christof Renner (22301943)
Manuel Friedl (12306626)

Betreuer:

Prof. Dr. Martin Schramm

Datum: 20. April 2026

Pitch

Ausgangslage und Motivation

Moderne Softwareentwicklung basiert auf hochgradig automatisierten Build-, Test- und Deployment-Prozessen. Diese CI/CD-Pipelines sind tief in cloud-native Infrastrukturen integriert und verfügen über weitreichende Zugriffsrechte auf sensible Ressourcen wie Secrets, Container-Registries und Produktionsumgebungen. Angriffe auf Softwarelieferketten – etwa SolarWinds (2020) oder der 3CX-Vorfall (2023) – belegen, dass der Entwicklungsprozess selbst zu einem primären Angriffsziel geworden ist. Im Sinne des Security Engineering soll daher nicht ein einzelnes Tool, sondern die sicherheitstechnische Analyse des gesamten Pipeline-Systems im Vordergrund stehen.

Zielsetzung

Ziel der Arbeit ist es, eine repräsentative CI/CD-Pipeline systematisch unter Sicherheitsgesichtspunkten zu untersuchen. Im Mittelpunkt stehen dabei die Identifikation schützenswerter Assets (Quellcode, Build-Artefakte, Secrets, Deployment-Credentials), relevanter Trust Boundaries sowie möglicher Angreifer, ihrer Fähigkeiten und Motivation. Darauf aufbauend sollen wesentliche Bedrohungen für zentrale Pipeline-Stufen herausgearbeitet und hinsichtlich ihrer Relevanz für das Gesamtsystem eingeordnet werden.

Methodisches Vorgehen

Zunächst wird eine exemplarische CI/CD-Pipeline modelliert (z. B. auf Basis von GitHub Actions oder GitLab CI), um sicherheitsrelevante Übergänge und Angriffsflächen sichtbar zu machen. Anschließend erfolgt eine strukturierte Bedrohungsanalyse auf Basis von STRIDE, angewendet auf die einzelnen Pipeline-Stufen (Source → Build → Test → Deploy). Für die identifizierten Bedrohungen werden geeignete technische Sicherheitsmechanismen abgeleitet und begründet – darunter Secret Management, Software Bill of Materials (SBOM), Code-Signing, Branch-Protection-Policies sowie Runner-Isolation. Abschließend wird bewertet, inwieweit diese Maßnahmen die Sicherheitslage des Systems tatsächlich verbessern, und verbleibende Restrisiken werden transparent gemacht.

Erwarteter Mehrwert

Die Arbeit soll zeigen, wie sich ein moderner DevOps-Prozess im Sinne des Security Engineering nicht nur funktional, sondern auch methodisch absichern lässt. Das angestrebte Ergebnis ist ein nachvollziehbares und praxisnahes Sicherheitskonzept, das typische Bedrohungen einer CI/CD-Pipeline systematisch erfasst, geeignete Gegenmaßnahmen begründet und den Zielkonflikt zwischen Deployment-Geschwindigkeit und Security-Assurance – inklusive der zugrundeliegenden Anreizstrukturen – transparent macht.